IAM-Local

Guide d'administration & d'utilisation

IDENTITY & ACCESS MANAGEMENT | SSO | V1.1.0

Gestion des utilisateurs, applications, rôles, permissions
intégration SSO automatique, audit et sécurité

Documentation utilisateur — Octobre 2026

Sommaire

1. 1. Qu'est-ce que IAM-Local ?
2. 2. Installation de la plateforme
3. 2b. Compte initial et accès
4. 3. Première connexion
5. 4. Le portail « Mes applications »
6. 5. La console d'administration
7. 6. Gestion des utilisateurs
8. 7. Gestion des applications & intégration SSO automatique
9. 8. Rôles & permissions
10. 9. Organisations
11. 10. Sessions utilisateurs
12. 11. Journal d'audit
13. 12. Paramètres — politique de mot de passe
14. 13. Mon profil (espace utilisateur)
15. 14. Authentification à deux facteurs (MFA)
16. 15. Fonctionnement du SSO (technique)
17. 16. Bonnes pratiques & dépannage
18. 17. Diagramme UML de classes
19. 18. Diagramme UML d'activité

1. Qu'est-ce que IAM-Local ?

IAM-Local est une plateforme PHP d'**identité et de contrôle d'accès** (Identity & Access Management) pensée pour un environnement d'évaluation local (WAMP / XAMPP). Elle centralise :

- les **comptes utilisateurs** (identités) ;
- les **applications** protégées par authentification unique (**SSO**) ;
- les **rôles** et **permissions** par application ;
- les **organisations** (hiérarchie ministère → direction → service) ;
- la **politique de mots de passe**, les **sessions** et le **journal d'audit**.

1.1 Vocabulaire essentiel

Terme	Définition
Identité	Compte d'un utilisateur (nom, e-mail, identifiant, matricule…).
Application	Système tiers (ex. « Gestion des Présences ») protégé par l'IAM.
SSO	Authentification unique : une seule connexion IAM donne accès à toutes les applications autorisées.
Rôle	Regroupement de permissions (ex. « Directeur », « Agent », « Auditeur »).
Permission	Droit précis dans une application (ex. `salary.validate`, `presence.record`).
Organisation	Structure hiérarchique (ministère, direction, service, bureau) à laquelle les utilisateurs sont rattachés.
Garde SSO	Fichier généré automatiquement par l'IAM qui protège les pages d'une application.

1.2 Deux espaces distincts

ℹ️ IAM-Local sépare l'**espace utilisateur** (portail, profil) de la **console d'administration** (réservée au rôle `admin`).

Espace	Accès	Contenu
Portail utilisateur	Tout utilisateur connecté	Mes applications, mon profil, changement de mot de passe, sessions.
Console d'administration	Rôle « admin » uniquement	Tableau de bord, utilisateurs, rôles, applications, organisations, sessions, audit, paramètres.

2b. Compte initial et accès

⚠️ Le mot de passe initial est affiché une seule fois à la fin de l'installation. Il n'est pas inclus dans ce guide : conservez-le dans un gestionnaire de mots de passe et changez-le à la première connexion.

Les comptes de démonstration dépendent des données chargées dans la base. Consultez **Administration** → **Utilisateurs** pour vérifier les comptes existants, leur état et leurs rôles; n'utilisez pas un compte de démonstration en production.

Accès aux consoles

Ressource	Adresse
Page de connexion IAM	`http://localhost/IAM-Local/login.php`
Portail utilisateur	`http://localhost/IAM-Local/portal.php`
Console d'administration	`http://localhost/IAM-Local/admin/` (rôle admin requis)
Application Gestion des Présences	`http://localhost/GestionPresnceAdenIAM/`
Application Gestion des Salaires	`http://localhost/GestionSalaireAden/`

ℹ️ L'administrateur de la plateforme ouvre la console à `http://localhost/IAM-Local/admin/`. Les autres utilisateurs accèdent uniquement aux applications pour lesquelles un rôle leur a été attribué.

2. Installation de la plateforme

2.1 Prérequis

- Serveur web **Apache** + **PHP 8.x** (WAMP, XAMPP) avec extensions `pdo_mysql`, `mbstring`, `openssl`.
- Serveur **MySQL 8** (port 3306 par défaut).
- La plateforme copiée dans le dossier web (ex. `htdocs/IAM-Local` ou `www/IAM-Local`).

2.2 Déroulement

Avec Apache lancé, la plateforme redirige automatiquement vers `install.php` tant qu'elle n'est pas installée (présence du fichier `.installed`).

1. **Informations de plateforme** : nom de la plateforme (ex. « IAM-Local ») et URL de base auto-détectée (ex. `http://localhost/IAM-Local`).
2. **Connexion MySQL** : hôte (ex. `localhost`), port (`3306`), utilisateur (ex. `root`), mot de passe, nom de la base (ex. `iam_local`). La base et son schéma sont créés automatiquement.
3. **Compte administrateur** : nom, prénom, identifiant, e-mail, matricule. Le **mot de passe initial** peut être laissé vide : il sera généré automatiquement au format `Admin@XXXX`. Il est obligatoire de le changer à la première connexion.
4. Case « Données de démonstration (ADEN, Présences/Salaires) » cochée par défaut : ajoute les applications et rôles d'exemple.
5. Cliquer sur **Installer**.

⚠️ À la fin de l'installation, l'écran affiche les identifiants de l'administrateur **en clair** : copiez-les immédiatement. Le mot de passe devra être changé au premier accès.

2.3 Réinstallation / mise à jour

Sur l'écran « Déjà installé », le bouton **Réinstaller / mettre à jour** (`install.php?reset=1`) ré-exécute l'installation de façon **idempotente** : le schéma et les données sont mis à jour sans destruction. Un nouveau secret JWT est généré, ce qui invalide les jetons précédents.

2.4 Vérification des fichiers

```
IAM-Local/
  .installed          <- marqueur d'installation
  config/config.php   <- configuration & secret JWT
  install.php         <- installateur
  login.php, mfa.php  <- connexion, 2 facteurs
  portal.php          <- portail utilisateur
  profile.php         <- profil / mot de passe
  admin/              <- console d'administration
```

```
api/                <- API JSON (login, userinfo, sso/validate...)
client/             <- bibliothèque SSO pour applications externes
```

3. Première connexion

1. Ouvrir `http://localhost/IAM-Local/login.php`.
2. Saisir l'**adresse e-mail**, l'**identifiant** ou le **numéro de téléphone** du compte, puis le **mot de passe**.
3. Cliquer sur **Se connecter**.
4. Si c'est un premier accès (`must_change_password`), la plateforme force le changement de mot de passe via **Mon profil** → **Changer le mot de passe**.
5. Vous arrivez sur le **portail des applications**.

3.1 Règles de connexion (sécurité)

Règle	Valeur par défaut
Longueur minimale du mot de passe	8 caractères
Complexité exigée	majuscule, minuscule, chiffre, caractère spécial
Verrouillage après échecs successifs	5 échecs → verrouillage 30 min
Expiration du mot de passe	90 jours
Historique mémorisé	5 derniers mots de passe (non réutilisables)
Durée de session	1 h (3600 s)
Inactivité avant déconnexion	30 min (1800 s)

3.2 Messages d'erreur courants

Message	Signification
Identifiants incorrects.	E-mail/login ou mot de passe erroné.
Compte désactivé ou en attente de validation.	Statut du compte `inactive` ou `pending`.
Compte temporairement verrouillé.	Verrouillage en cours (déverrouillage automatique après la durée prévue).
Trop de tentatives. Réessayez plus tard.	Limite anti force brute franchie.
Session expirée. Réessayez.	Jeton de sécurité (CSRF) de la page expiré → rechargez la page.

3.3 Connexion sans mot de passe (OTP)

Depuis la page de connexion, le lien « **Se connecter sans mot de passe** » ouvre `otp_login.php` :

1. Saisir son **adresse e-mail** ou son **numéro de téléphone** puis cliquer **Recevoir mon code**.

2. Saisir le **code à usage unique** reçu par e-mail (valable 5 minutes, 5 essais max).
3. Après vérification, la session est ouverte (le mot de passe n'est pas saisi).
4. Code perdu ? Clien sur **« Renvoyer le code »** (`?resend=1`).

ℹ️ Ce mode est utile pour les comptes dont le mot de passe est oublié ou sur mobile, sans passer par l'administrateur. Les comptes peuvent aussi être verrouillés (comme pour une connexion classique) après trop d'échecs.

4. Le portail « Mes applications »

Après connexion, le portail liste les applications accessibles à l'utilisateur selon ses rôles :

- chaque application est présentée sous forme de **carte** (icône colorée, nom, description, code) ;
- le bouton **Accéder** lance la connexion SSO et ouvre l'application ;
- un bloc **Mes rôles** affiche tous les rôles attribués.

ℹ️ Si l'utilisateur doit changer son mot de passe, un bandeau d'avertissement apparaît et l'accès est suspendu tant que le mot de passe n'est pas modifié.

4.1 En-tête et navigation

- **Avatar + nom + e-mail** : lien vers **Mon profil**.
- **Déconnexion** : clôture la session (révoquée en base, journal d'audit).
- La section de navigation « Administration » n'apparaît **que pour les administrateurs**.

4.2 Accéder à une application

1. Cliquer sur **Accéder** sur la carte de l'application.
2. L'IAM vérifie que le compte a bien un rôle sur cette application (sinon refus).
3. L'IAM émet un **jeton temporaire** et redirige l'utilisateur vers l'application.
4. L'application crée sa propre session : l'utilisateur est connecté sans ressaisir son mot de passe.

L'accès **direct** à l'URL d'une application protégée (sans passer par le portail) fonctionne aussi : l'application protégée redirige automatiquement vers la page de connexion IAM puis ramène l'utilisateur sur la page demandée.

5. La console d'administration

Accessible uniquement aux utilisateurs ayant le rôle `admin`. La barre latérale donne accès à 10 rubriques :

Rubrique	Fichier	Rôle
Tableau de bord	`admin/index.php`	Statistiques globales (utilisateurs, comptes actifs, applications, rôles, sessions actives, MFA, événements), utilisateurs par application, dernières connexions.
Utilisateurs	`admin/users.php`	Créer, modifier, supprimer, réinitialiser les mots de passe, attribuer rôles/apps, importer en CSV, gérer direction/service/fonction et groupes.
Groupes	`admin/groups.php`	Créer des annuaires de groupes et gérer leurs membres.
OAuth / OIDC	`admin/oauth.php`	Créer/modifier les clients OAuth 2.0, afficher le secret une seule fois, autoriser les URIs de redirection et réaliser la rotation de la clé de signature.
Rôles & permissions	`admin/roles.php`	Créer des rôles, attacher des permissions par application.
Applications	`admin/apps.php`	Créer/modifier des applications, gérer les permissions, les accès utilisateurs et le déploiement SSO.
Organisations	`admin/organizations.php`	Construire l'arbre organisationnel et rattacher les utilisateurs.
Sessions	`admin/sessions.php`	Lister, filtrer et révoquer les sessions actives.
Journal d'audit	`admin/audit.php`	Consulter tous les événements (connexions, créations, modifications...).
Paramètres	`admin/settings.php`	Configurer la politique de mots de passe.

⚠️ La console est réservée au rôle `admin` attribué à l'application `iam-admin`. Un rôle `admin` métier ne donne pas l'administration de la plateforme.

6. Gestion des utilisateurs

Menu Administration → **Utilisateurs**. La liste affiche : utilisateur (nom + e-mail), matricule, organisation, rôles par application, statut, badge MFA, dernière connexion et les actions.

- **Recherche** : champ en haut de page (nom, e-mail, matricule).
- **Pagination** : 15 utilisateurs par page.
- **Bouton « Nouvel utilisateur »** : ouvre la fenêtre de création.

6.1 Créer un utilisateur

1. Cliquer sur **Nouvel utilisateur**.
2. Renseigner : **Prénom***, **Nom***, **E-mail*** (obligatoires), **Téléphone**, **Identifiant (login)** (vide = e-mail), **Matricule**, **Organisation**, **Direction / Service / Fonction**.
3. Saisir un **Mot de passe temporaire*** respectant la politique (min. 8 caractères + majuscule + chiffre + spécial).
4. Dans **Rôles par application**, choisir un rôle pour chaque application concernée (option « — Aucun — » possible).
5. Cocher les **Groupes** éventuels dans la liste à cocher.
6. Cliquer sur **Créer**.

ℹ️ À la création, le compte est créé avec le drapeau **« changer le mot de passe à la prochaine connexion »**. C'est l'utilisateur qui choisira son propre mot de passe.

6.2 Modifier un utilisateur

- Clic sur l'icône ✍️ **crayon** d'une ligne.
- Modifier prénom, nom, e-mail, téléphone, matricule, organisation, **direction/service/fonction**, **groupes** et **statut** (active , inactive , locked).
- Ajuster les **rôles par application**.
- Cliquer sur **Enregistrer**. Les rôles sont remplacés par la nouvelle sélection.

6.3 Réinitialiser le mot de passe

- Clic sur l'icône 🔑 **clé** d'une ligne.
- Saisir un **nouveau mot de passe** respectant la politique.
- Cliquer sur **Réinitialiser**. L'utilisateur devra le changer à sa prochaine connexion.

6.4 Supprimer un utilisateur

- Clic sur l'icône 🗑 **corbeille** (avec confirmation).
- L'administrateur principal (id 1) ne peut **pas** être supprimé.

6.5 Import CSV

Dans la liste des utilisateurs, le bouton **« Importer »** ouvre une fenêtre : téléchargez le **modèle CSV** (bouton « Télécharger le modèle »), remplissez-le puis importez-le. Règles :

- Utilisez le modèle fourni par le bouton **Télécharger le modèle CSV**. Les en-têtes sont : `email`, `first_name`, `last_name`, puis les champs facultatifs `username`, `phone`, `matricule`, `organization`, `department`, `service`, `fonction` et `status`.
- Le séparateur point-virgule ou virgule est détecté automatiquement; l'encodage UTF-8 avec BOM est accepté. E-mail, prénom et nom sont obligatoires.
- Les e-mails déjà utilisés sont ignorés. Les lignes incomplètes sont signalées; l'organisation est recherchée par code ou nom.
- Un mot de passe aléatoire est créé et le changement au prochain accès est exigé. Distribuez les accès par un canal sûr.

6.6 Gérer les groupes

Menu Administration → **Groupes** : créer, renommer ou supprimer des groupes (annuaires transverses, ex. « Encadrement », « Commission ») et gérer leurs membres. Les groupes sélectionnés dans un utilisateur apparaissent aussi dans les formulaires de création/modification (« Groupes »).

✅ Toutes ces opérations sont tracées dans le **journal d'audit** (`user_created`, `user_updated`, `user_deleted`, `password_reset`).

7. Gestion des applications & intégration SSO automatique

Menu `Administration` → **Applications**. Chaque application est présentée par une **carte** : icône colorée, nom, description, URL, badges d'état et boutons d'action.

7.1 Créer une application

1. Cliquer sur **Enregistrer une application**.
2. Renseigner les champs :

Champ	Obligatoire	Description
Code	oui	Identifiant unique (minuscules, tirets) ex. `gestion-conges`.
Nom	oui	Nom affiché ex. « Gestion des Congés ».
Description	non	Texte court affiché sur la carte.
URL	oui	Adresse racine de l'application ex. `http://localhost/App`.
Redirect URI (SSO)	non	Automatiquement `<URL>/iam-sso-<code>.php` si vide.
Couleur	non	Couleur de l'icône (défaut `#4361ee`).
Icône (FontAwesome)	non	Classe d'icône (défaut `fa-cube`).
Active	—	Cochée : l'application peut être utilisée en SSO.

3. Cliquer sur **Enregistrer**.

7.2 Déploiement SSO automatique

À la création (ou si l'URL change), l'IAM **déploie automatiquement l'intégration SSO** dans le dossier local de l'application :

- génération d'un **client_id** (`iam-native-<code>`) et d'un **client_secret** unique ;
- génération du fichier **garde** `iam-sso-<code>.php` à la racine de l'application ;
- ajout dans le fichier `.htaccess` de l'application d'un bloc `auto_prepend_file` qui charge le garde sur **toutes les pages PHP**.

✅ Résultat : l'accès direct au lien de l'application redirige automatiquement vers l'IAM pour la connexion, puis ramène l'utilisateur sur la page demandée — sans aucune modification de code côté application.

7.3 Le panneau « Intégration SSO »

La carte de chaque application affiche l'état de la protection et propose :

Statut affiché	Signification
Active (lien direct protégé)	Fichier garde + .htaccess présents : protection active.

Fichier présent, .htaccess manquant	Le garde existe mais le chargement automatique n'est pas en place.
Déploiement manuel	Application hébergée hors du disque local (serveur distant) : déployer le garde manuellement.
Non déployée / Dossier introuvable	Protection à mettre en place ou chemin local non résolu.

Boutons disponibles :

- **Télécharger le fichier d'intégration** → récupère `iam-sso-<code>.php` (pour un déploiement manuel).
- **Générer / redéployer** → relance le déploiement (idempotent).
- **Retirer la protection** → supprime le fichier garde et le bloc .htaccess généré.

7.4 Permissions de l'application

Le bouton **Permissions (N)** ouvre la gestion des permissions de l'application :

- Modifier directement le **nom**, le **code** et la **description** d'une permission puis cliquer **Enregistrer**.
- Supprimer une permission après confirmation; elle est alors retirée des rôles qui la portaient.
- Ajouter une permission avec son **nom***, son **code*** et une description.

> Le code est unique dans toute la plateforme et peut être utilisé dans le code de l'application. Avant de le modifier, repérez ses usages et mettez-les à jour; testez ensuite l'accès autorisé et le refus des autres rôles.

7.5 Accès utilisateurs

Le bouton **Accès utilisateurs (N)** gère qui peut accéder à l'application :

- **Utilisateurs autorisés** : liste des utilisateurs avec leur rôle et un bouton de retrait ;
- **Donner l'accès** : sélection d'un utilisateur actif + d'un rôle, puis bouton **Donner l'accès**.

7.6 Supprimer une application

Bouton corbeille (les applications système, `is_system=1`, ne peuvent pas être supprimées).

> ⚠️ Pour une application hébergée **hors localhost** (serveur distant), le déploiement automatique est impossible (statut « Déploiement manuel ») : téléchargez le fichier garde et incluez-le via `require_once __DIR__ . '/iam-sso-<code>.php';` dans les pages à protéger, ou déposez-le à la racine avec le .htaccess correspondant.

8. Rôles & permissions

Menu `Administration` → **Rôles & permissions**. Chaque rôle appartient à une application. Les cartes affichent le nom, le code, l'application propriétaire, la description, le nombre de permissions et le nombre d'attributions.

8.1 Profils standards

Code	Profil	Principe d'accès
`admin`	Administrateur	Accès complet à son application; seul le rôle admin de l'application `iam-admin` administre la plateforme.
`gestionnaire_rh`	Gestionnaire RH	Opérations métier définies par les permissions de chaque application.
`agent`	Agent	Consultation uniquement; aucune création, modification, suppression ou validation.
`auditeur`	Auditeur	Consultation et export si l'application lui attribue une permission d'export; aucune écriture.

Des rôles métier propres à certaines applications peuvent compléter ces profils (par exemple `employe`, `technicien`, `operateur` ou `magasinier`). Un rôle affichant **0 permission** ne donne aucun accès métier à un utilisateur non administrateur.

8.2 Créer un rôle

1. Cliquer sur **Créer un rôle**.
2. Saisir **Nom du rôle*** (ex. « Superviseur Paie ») et **Code*** (ex. `superviseur_paie`).
3. Ajouter éventuellement une **description**.
4. Cliquer sur **Créer**.

8.3 Attribuer des permissions

1. Sur la carte du rôle, cliquer sur **Permissions**.
2. La fenêtre présente les permissions groupées **par application**.
3. Cocher/décocher les permissions souhaitées (badges cliquables).
4. Cliquer sur **Enregistrer**.

ℹ️ Les permissions des rôles système peuvent être configurées graphiquement. Leur nom et leur code restent protégés, et leur suppression est interdite.

8.4 Supprimer un rôle

Bouton corbeille sur une carte de rôle non système (avec confirmation). Un rôle système ne peut pas être supprimé.

9. Organisations

Menu `Administration` → **Organisations**. Construit un **arbre hiérarchique** : ministère → direction générale → direction → service → bureau.

9.1 Types d'organisation

`ministère` `direction_generale` `direction` `service` `bureau` `autre`

9.2 Créer une organisation

1. Cliquer sur **Nouvelle organisation**.
2. Saisir **Nom*** (obligatoire), **Code**, choisir le **type** et l'**organisation parente** (« — Aucune (racine) — » pour une racine).
3. Cliquer sur **Créer**.

9.3 Modifier / supprimer

- **Modifier** (icône crayon) : nom, code, type, parent.
- **Supprimer** : possible uniquement si aucun utilisateur n'est rattaché (« Cette organisation contient des utilisateurs. Déplacez-les d'abord. »).

Les utilisateurs sont rattachés à une organisation au moment de leur création ou modification (page Utilisateurs).

10. Sessions utilisateurs

Menu Administration → **Sessions**. Liste de toutes les sessions IAM actives avec : utilisateur, IP, navigateur (user-agent), création, dernière activité, expiration, statut et actions.

10.1 Statuts

Statut	Signification
active	Session en cours, non expirée.
expirée	La date d'expiration est dépassée.
révoquée	Session invalidée manuellement ou à la déconnexion.

10.2 Révoquer

- Icône 🚫 rouge : révoque **une** session.
- Icône 🚫 encadrée : révoque **toutes** les sessions d'un utilisateur (ex. matériel volé).

ℹ️ Filtre par utilisateur (select) + bouton **Filtrer** pour restreindre la liste. Les révocations sont journalisées (`session_revoked` , `sessions_revoked`).

11. Journal d'audit

Menu Administration → **Journal d'audit**. Trace exhaustive et horodatée des actions sensibles.

11.1 Filtres

- Champ de recherche **q** (e-mail, action, détails, IP).
- Select **action** : filtre par type d'événement.
- Boutons **Filtrer** (🔍) et **Effacer** (retour à la liste complète).

11.2 Informations affichées

Date, action (badge coloré), utilisateur (e-mail + identifiant), détails, IP, navigateur. Si la géolocalisation est activée (`geoip_lookup`, voir « Paramètres »), une colonne **pays** apparaît (IP privée = « Réseau local »). Pagination : 30 lignes par page.

11.3 Événements principaux tracés

login_success password_changed password_reset user_created user_updated app_created app_access_granted role_created sso_issue sso_login mfa_verified group_created import_users oauth_consent oauth_token oauth_client_credentials oauth_client_created oauth_key_rotated account_locked mfa_lockout session_revoked user_deleted sso_removed

12. Paramètres — politique de mot de passe

Menu `Administration` → **Paramètres**. Configure la politique de sécurité des mots de passe :

12.1 Champs disponibles

Paramètre	Défaut	Description
Longueur minimale	8	Nombre minimal de caractères (4 à 32).
Historique (nb de mots de passe mémorisés)	5	Empêche la réutilisation immédiate (0 à 20).
Expiration (jours)	90	Durée de validité du mot de passe (0 = jamais).
Verrouillage après (tentatives échouées)	5	Nombre d'échecs avant verrouillage.
Durée de verrouillage (minutes)	30	Temps de verrouillage du compte.
Durée de session (secondes)	3600	Durée maximale de la session.
Durée avant inactivité (secondes)	1800	Déconnexion automatique après inactivité.

12.2 Complexité exigée

- **Au moins une lettre majuscule** (`require_upper`)
- **Au moins une lettre minuscule** (`require_lower`)
- **Au moins un chiffre** (`require_digit`)
- **Au moins un caractère spécial** (`require_special`)

Après modification, cliquer sur **Enregistrer la politique**. Un audit `policy_updated` est émis.

12.3 Informations plateforme (lecture seule)

La page affiche aussi les informations statiques : nom (`IAM_NAME`), version, URL, base de données, état SMTP et récapitulatif de la politique active.

> ℹ️ Le SMTP sert à l'envoi des codes MFA par e-mail. Non configuré, l'IAM passe en **mode démonstration** : le code OTP s'affiche directement à l'écran.

12.4 API & sécurité

Dans la carte « API & sécurité » de la même page :

Paramètre	Défaut	Description
Origines autorisées (CORS) — `cors_origins`	`*`	Liste séparée par des virgules des origines autorisées à appeler l'API IAM depuis un navigateur (ex. `https://app.monchantier.ci, http://localhost:8080`). `*` = toutes les origines (API publique).

Recherche du pays des IP — `geoip_lookup`	désactivé	Active la géolocalisation des adresses IP publiques (service ip-api.com, données **non stockées**) pour renseigner la colonne « pays » des journaux d'audit. Les IP privées/locales restent affichées « Réseau local ».

⚠️ Protection anti brute-force par IP : **60 échecs max / 15 minutes** par adresse IP (constantes `IP_RATE_MAX_ATTEMPTS` / `IP_RATE_WINDOW_MINUTES`), appliquée aux pages **et** aux API de connexion, en plus du verrouillage par compte (5 échecs / 30 min).

13. Mon profil (espace utilisateur)

À l'écran « Mon profil » (`profile.php`), chaque utilisateur dispose de :

13.1 Informations personnelles (lecture seule)

Nom complet, identifiant, e-mail, téléphone, matricule, organisation, dernière connexion, état MFA (Activé / Désactivé).

13.2 Rôles et applications

Liste des applications accessibles, rôles par application et permissions rattachées (badges de codes).

13.3 Changer son mot de passe

Champ	Description
Mot de passe actuel *	Mot de passe actuel du compte.
Nouveau mot de passe *	Doit respecter la politique (min. 8 caractères, majuscule, minuscule, chiffre, caractère spécial).
Confirmer le nouveau mot de passe *	Identique au précédent.

Bouton **Mettre à jour**. Le mot de passe doit être différent du précédent et absent de l'historique récent.

13.4 Mes sessions actives

Table des sessions ouvertes (IP, navigateur, création, expiration) et bouton **« Tout déconnecter ailleurs »** qui révoque toutes les sessions autres que la session courante.

14. Authentification à deux facteurs (MFA)

Lorsqu'un compte a la MFA activée, la connexion est suivie d'une vérification par **code OTP à 6 chiffres** :

1. Connexion classique (identifiant + mot de passe).
2. Redirection vers `mfa.php` : un code à 6 chiffres est **envoyé par e-mail**.
3. Saisie du code puis bouton **Vérifier et continuer**.

14.1 Liens utiles

- **Renvoyer le code** : émet un nouveau code.
- **Annuler** : déconnecte et revient à la page de connexion.

14.2 Règles

- Validité du code : 5 minutes.
- 5 échecs maximum → la session est détruite et l'utilisateur renvoyé à la page de connexion (`mfa_lockout` tracé).
- **Mode démonstration** : sans SMTP configuré, le code OTP est affiché directement à l'écran dans un encart orange.

⚠️ L'activation/désactivation de la MFA n'est pas exposée dans l'interface administrateur : elle se règle en base (colonne `mfa_enabled` de la table `users`).

15. Fonctionnement du SSO (référence technique)

Le SSO repose sur la **rédemption d'un jeton à usage unique** : l'IAM émet un jeton, l'application le consomme auprès de l'API IAM et ouvre sa session locale.

15.1 URL impliquées

Adresse	Rôle
`IAM_BASE_URL/sso/authorize.php?app=<code>&return=<url>&prompt=login`	Point d'entrée SSO : vérifie l'accès et émet le jeton.
`IAM_BASE_URL/login.php`	Connexion utilisateur.
`IAM_BASE_URL/mfa.php`	Vérification 2 facteurs (si activée).
`IAM_BASE_URL/api/sso/validate.php`	API POST JSON `{token, app_code}` : consomme le jeton et renvoie l'utilisateur, les rôles et les permissions.
`IAM_BASE_URL/admin/download_sso.php?app=<code>`	Téléchargement du fichier garde.

15.2 Scénario : accès direct à une application protégée

1. L'utilisateur ouvre `http://localhost/Application/page.php`.
2. Le garde `iam-sso-<code>.php` (chargé par `auto_prepend_file`) démarre une session locale isolée `iam_app_<code>`.
3. Non authentifié → redirection vers `sso/authorize.php?app=<code>&return=<page demandée>&prompt=login`.
4. `authorize.php` envoie l'utilisateur sur `login.php` (ou force la ressaisie si `prompt=login`).
5. Après connexion (et MFA / changement de mot de passe éventuels), retour sur `authorize.php`.
6. `authorize.php` vérifie : application **active**, utilisateur avec un **rôle** sur l'app (ou admin global), **URL de retour** sur le même hôte que l'application.
7. Jeton SSO à usage unique créé (validité 60 s) → redirection vers `returnUrl?sso_token=…`.
8. Le garde envoie le jeton à `api/sso/validate.php`, qui le consomme et renvoie `access_token` (JWT 1 h), profils, rôles, permissions.
9. Le garde ouvre la session locale, retire `sso_token` de l'URL et affiche la page.
10. Pages suivantes : `iam_sso_authenticated()` passe directement.

15.3 Fonctions fournies au développeur d'application

Fonction	Rôle

`iam_sso_authenticated()`	Indique si l'utilisateur est connecté via SSO.
`iam_sso_user()`	Retourne le profil (id, username, email, prénom, nom, matricule…).
`iam_sso_has_permission($code)`	Vérifie une permission (ex. `salary.validate`).
`iam_sso_logout()`	Clôture la session SSO locale.

15.4 Paramètres du point d'entrée SSO

Paramètre GET	Description
`app`	Code de l'application (obligatoire).
`return`	URL de retour (optionnelle ; doit appartenir à l'application, même hôte — port ignoré).
`prompt=login`	Force la ressaisie des identifiants IAM même si déjà connecté.

15.5 Réponses de l'API de validation

Code	Signification
200	Jeton valide → `access_token`, `user`, `roles`, `permissions`.
401	Jeton invalide, expiré ou déjà consommé.
403	Jeton non rattaché à l'application demandée.
422	Paramètre manquant (`token` / `app_code`).

15.6 Serveur OAuth 2.0 / OIDC (Authorization Code + PKCE)

L'IAM expose aussi un **serveur d'autorisation** pour les applications « tout type » (SPA, mobiles, services) :

Adresse	Rôle
`IAM_BASE_URL/oauth.php`	Demande d'autorisation + page de consentement (paramètres `response_type=code`, `client_id`, `redirect_uri`, `scope`, `state`, `code_challenge`, `code_challenge_method`, `nonce`).
`IAM_BASE_URL/api/oauth/token.php`	POST : échange du code (avec vérification PKCE) ou `refresh_token` (rotation : le jeton consommé est révoqué) ou `client_credentials`.
`IAM_BASE_URL/api/oauth/userinfo.php`	GET avec `Authorization: Bearer <access_token>` : profil OIDC (sub, name, email, poste…).
`IAM_BASE_URL/api/oauth/jwks.php`	Clés publiques de vérification des JWT (RS256).
`IAM_BASE_URL/.well-known/openid-configuration.php`	Découverte OIDC (issuer, endpoints, PKCE supporté).

- Scopes autorisés : `openid`, `profile`, `email`.
- L'`id_token` (JWT RS256) contient `sub`, `aud` (client), `iss`, `exp`, `iat`, `nonce` et les claims du profil demandé.

- La gestion des clients et la rotation de clé se font dans `Administration` → **OAuth / OIDC** ; le secret du client n'est affiché qu'à la création.
- Le consentement est demandé à l'utilisateur et le refus est journalisé (`access_denied`).

16. Bonnes pratiques & dépannage

16.1 Bonnes pratiques

- **Administrateur principal** : conservez le compte (id 1) ; il ne peut pas être supprimé et doit rester l'ultime recours.
- **Mots de passe temporaires** : utilisez le mot de passe généré aléatoirement par l'IAM et forcez son changement à la première connexion.
- **Rôles par app** : attribuez le rôle le moins privilégié nécessaire (principe du moindre privilège).
- **Sessions** : révoquez les sessions d'un utilisateur en cas de départ ou d'appareil perdu.
- **Audit** : consultez régulièrement le journal pour détecter les accès anormaux.
- **Organisations** : construisez l'arbre avant de créer les utilisateurs pour faciliter le rattachement.

16.2 Dépannage

Problème	Solution
« Écran Déjà installé » alors que je veux réinitialiser	Utiliser **Réinstaller / mettre à jour** (ré-exécution idempotente du schéma et des données).
Accès direct à une application non redirigé vers l'IAM	Vérifier le statut d'intégration SSO dans Applications : relancer **Générer / redéployer**.
« Dossier introuvable » après déploiement	Le chemin local n'est pas résolu depuis l'URL (serveur distant) : passage en déploiement manuel.
Utilisateur ne voit pas une application au portail	Lui attribuer un rôle sur cette application (Applications → Accès utilisateurs, ou Utilisateurs → Rôles par application).
403 « Vous n'avez pas accès à cette application »	Même cause : aucun rôle (et non admin) sur l'application.
403 « URL de retour invalide »	L'URL de retour n'a pas le même hôte que l'URL de l'application.
« Compte verrouillé »	Attendre la fin de la durée de verrouillage, puis réessayer.
Code MFA non reçu	SMTP non configuré : mode démonstration, le code s'affiche à l'écran ; sinon cliquer « Renvoyer le code ».
Fichier `.htaccess` modifié manuellement écrasé ?	L'IAM conserve une sauvegarde `.iam-backup-<date>` lors du redéploiement.

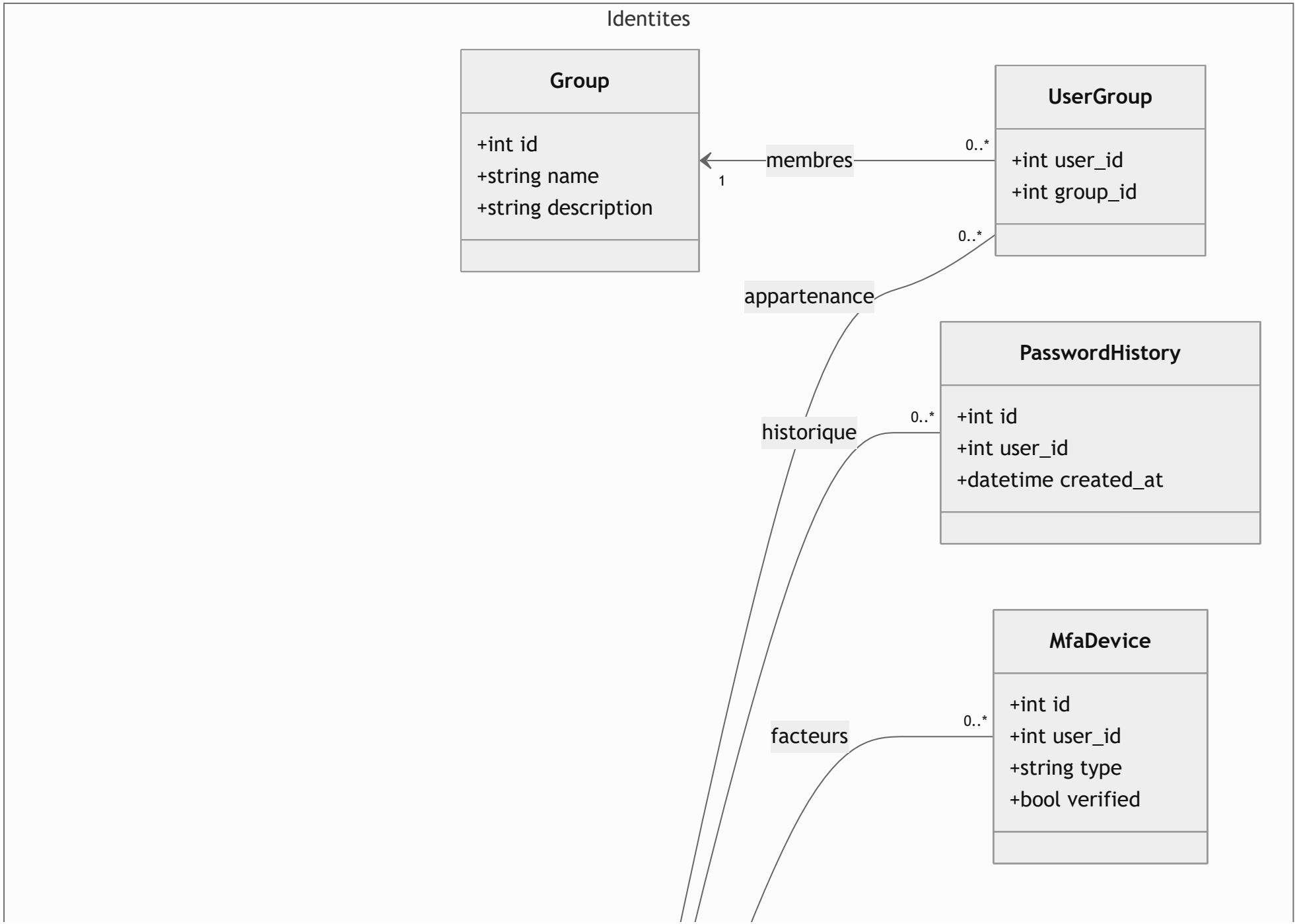
16.3 Annexe — Architecture des données

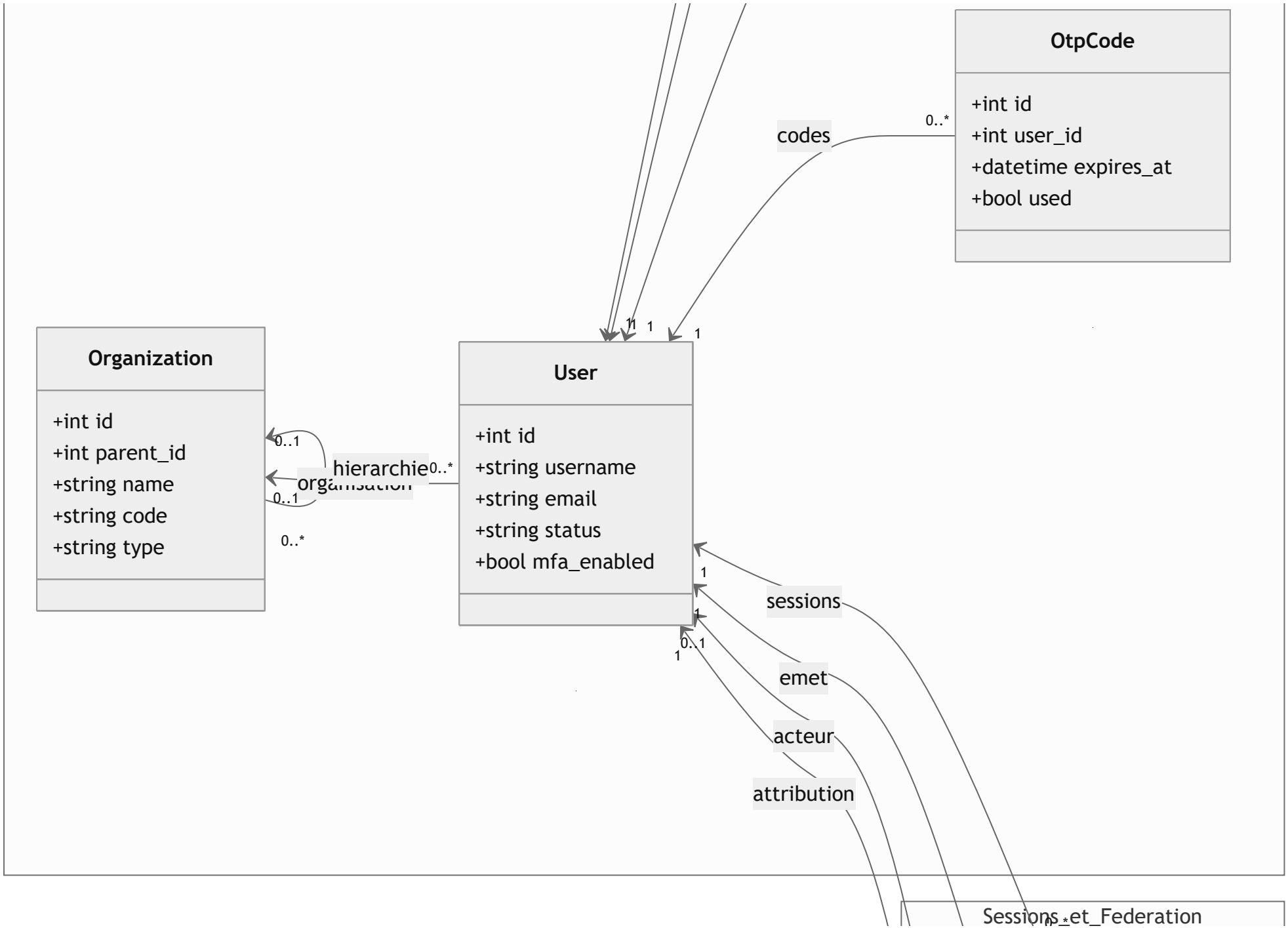
Table	Rôle
`organizations`	Hiérarchie organisationnelle.
`users`	Comptes utilisateurs (statut, MFA, verrouillage).
`applications`	Applications SSO (code, URL, client secret, actif).
`roles` / `permissions`	Rôles et droits.

`role_permissions` / `user_roles`	Matrices rôle→permission et utilisateur→rôle→application.
`sessions`	Sessions IAM révocables.
`sso_tokens`	Jetons SSO à usage unique.
`password_policy` / `password_history`	Politique de mots de passe et historique.
`mfa_devices` / `otp_codes`	2e facteur d'authentification.
`audit_logs` / `login_attempts`	Journal d'audit et anti force brute.

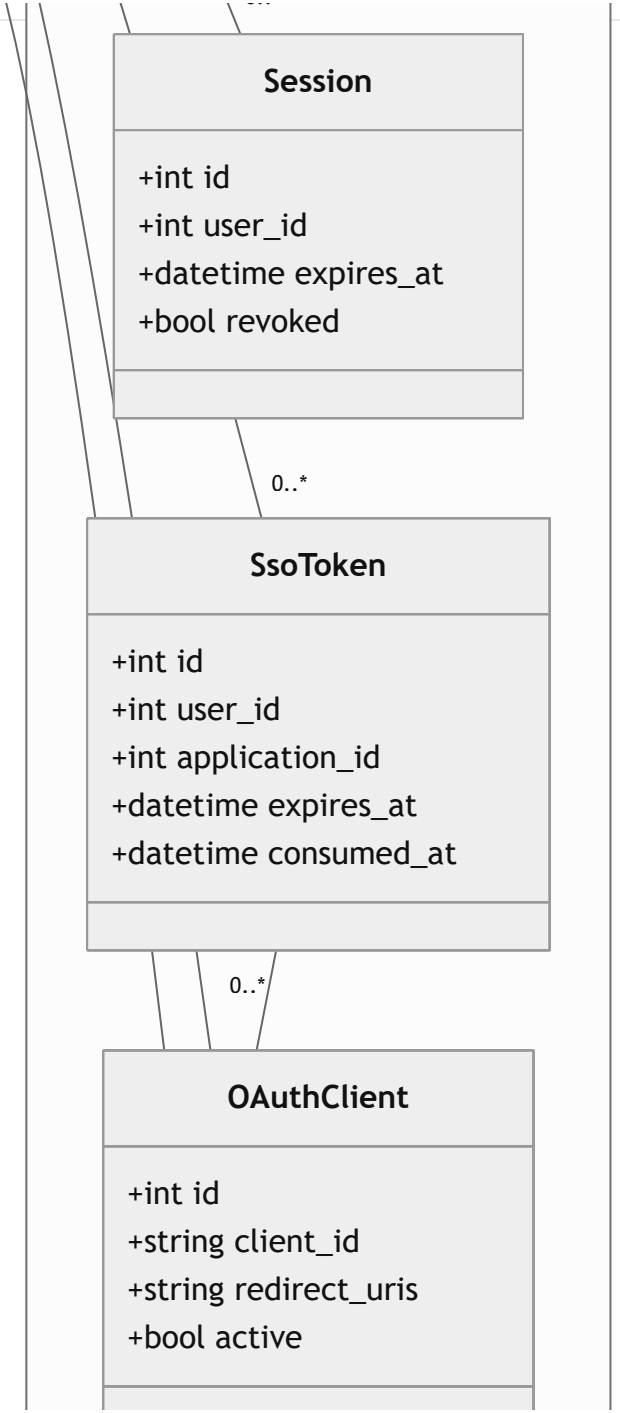
17. Diagramme UML de classes

Vue du modèle métier IAM : identités, organisations, applications, rôles, permissions, sessions, jetons SSO, MFA et audit. Les associations `UserRole` et `RolePermission` matérialisent les relations plusieurs-à-plusieurs.


Identites
Group
+int id
+string name
+string description
membres
1
0..*
UserGroup
+int user_id
+int group_id
0..*
appartenance
historique
0..*
PasswordHistory
+int id
+int user_id
+datetime created_at
facteurs
0..*
MfaDevice
+int id
+int user_id
+string type
+bool verified

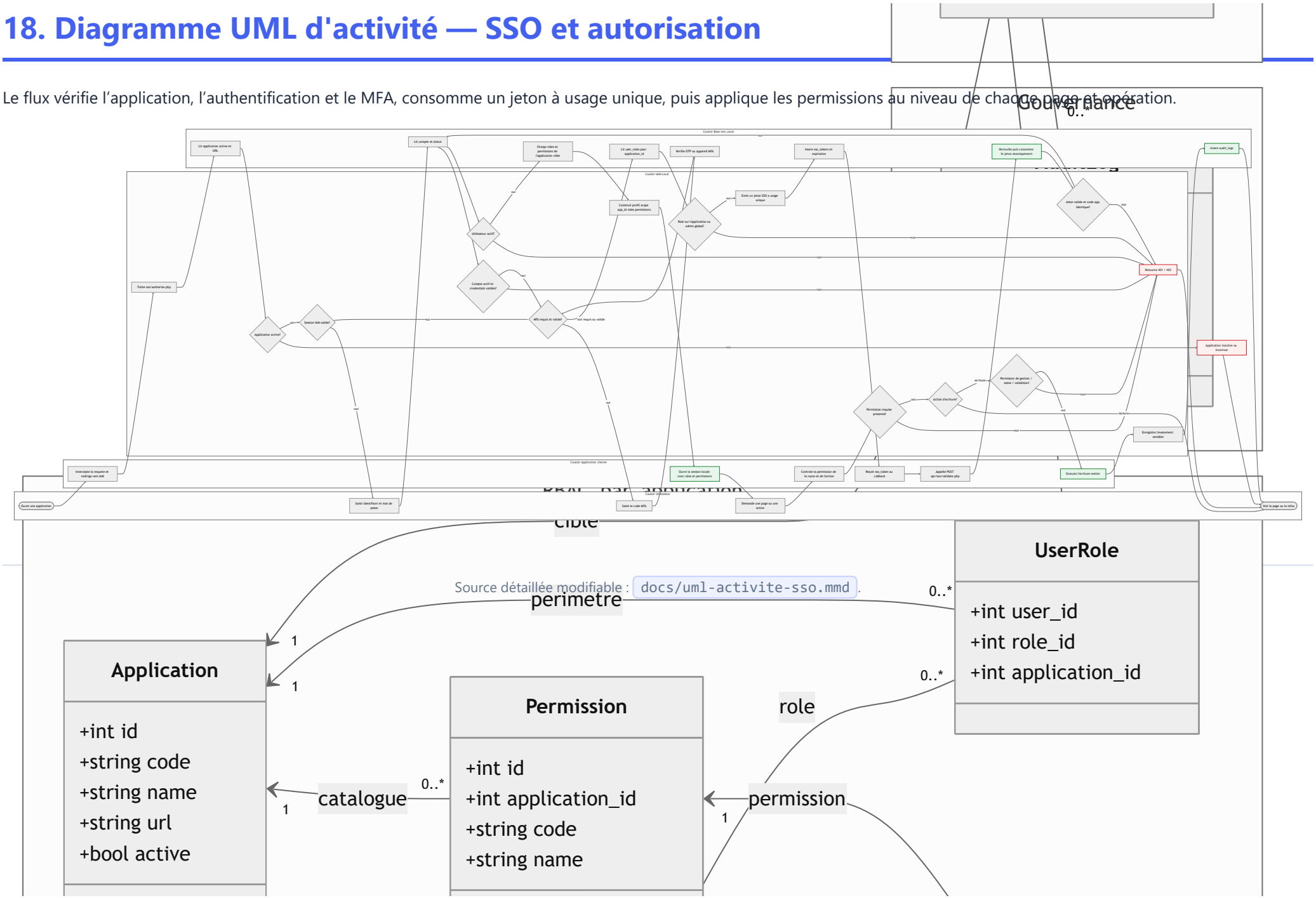

OtpCode
+int id
+int user_id
+datetime expires_at
+bool used
codes
0..*
1
1
1
Organization
+int id
+int parent_id
+string name
+string code
+string type
0..1
hierarchie
0..*
0..1
0..*
User
+int id
+string username
+string email
+string status
+bool mfa_enabled
1
sessions
1
0..1
1
emet
acteur
attribution
Sessions_et_Federation

Source détaillée modifiable : `docs/uml-classes.mmd`.

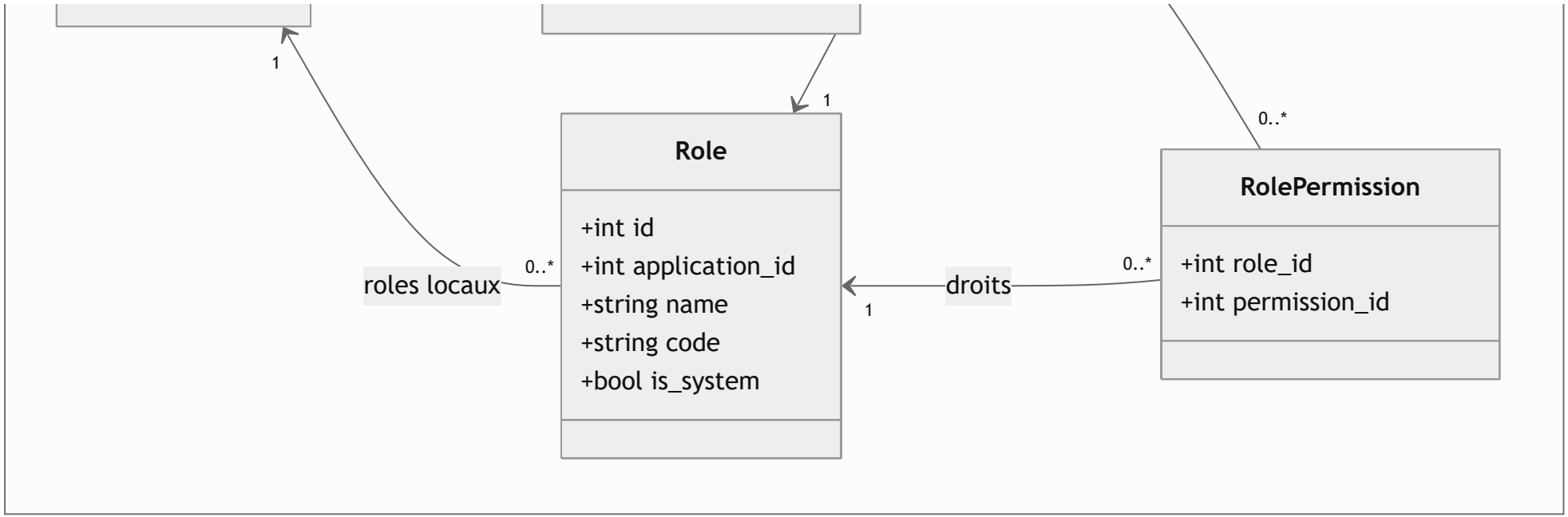


18. Diagramme UML d'activité — SSO et autorisation

Le flux vérifie l'application, l'authentification et le MFA, consomme un jeton à usage unique, puis applique les permissions au niveau de chaque page et opération.



Source détaillée modifiable : `docs/uml-activite-sso.mmd`.


1
1
0..*
Role
+int id
+int application_id
+string name
+string code
+bool is_system
RolePermission
+int role_id
+int permission_id
roles locaux
0..*
droits
0..*
1